

IT PROFESSIONAL PORTFOLIO

Cloud Engineering and Security Projects

PROJECT 38

Compare IMDSv1 and IMDSv2 Metadata Credential Risk

Amazon EC2 | IMDSv1 | IMDSv2 | IAM Roles | STS | SSRF

AUTHOR	Michael Salazar
ENVIRONMENT	Personal AWS Lab
VERSION	v1.0.0
RELEASE DATE	July 28, 2026
STATUS	Complete

Executive Summary

Created a new **IMDS** CloudFormation stack to test how the Amazon EC2 Instance Metadata Service exposes temporary instance role credentials. The lab compared an **IMDSv1-enabled** instance against an **IMDSv2-required** instance. On the IMDSv1 instance, a simple curl request to the metadata endpoint returned the instance profile role name and then returned temporary credentials. On the IMDSv2 instance, the same simple curl request failed with **401 Unauthorized**. A token had to be requested first, then supplied in request headers to retrieve the role name and temporary credentials. After validation, the stack and instances were deleted.

SECURITY OUTCOME

IMDSv2 is a major protection against simple SSRF credential theft because metadata requests need a token header. It does not stop a user or attacker who already has command-line execution on the instance.

Business Problem

Earlier labs showed static access-key exposure inside configuration files. This lab moves to the more common modern pattern: EC2 instances using IAM roles and instance profiles. Instance profiles are safer than long-lived access keys, but the temporary credentials are still available to the instance through the Instance Metadata Service. If an application on the instance has a Server-Side Request Forgery weakness, IMDSv1 can allow those role credentials to be retrieved through simple HTTP requests.

Objectives

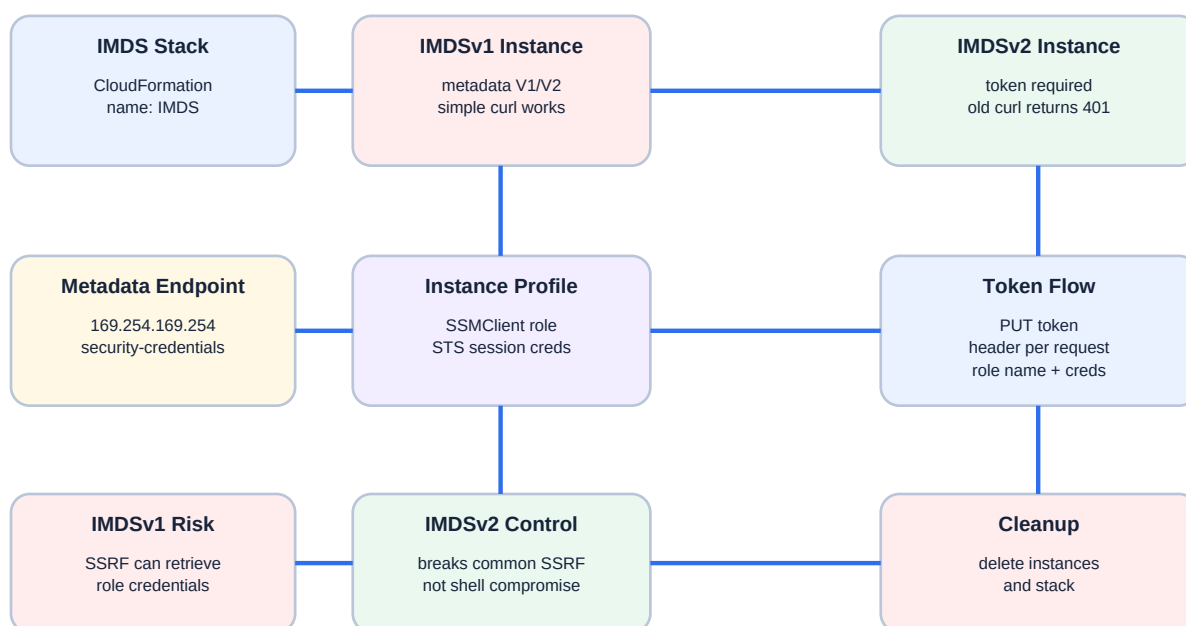
- * Create the IMDS CloudFormation stack from the provided template.
- * Deploy and compare two EC2 instances: one using IMDSv1 and one using IMDSv2.
- * Enable IMDSv1 behavior on the IMDSv1 test instance by allowing V1 and V2 token-optional metadata access.
- * Connect to the IMDSv1 instance and retrieve the SSMClient role name with a simple curl request.
- * Use a second simple curl request to retrieve temporary role credentials from IMDSv1.
- * Terminate the IMDSv1 connection and connect to the IMDSv2 instance.
- * Confirm the same simple metadata curl request fails against IMDSv2 with 401 Unauthorized.
- * Request an IMDSv2 token with a defined TTL, store it in memory, request the role name with the token header, and then retrieve credentials with the token and role name.
- * Delete the CloudFormation stack and instances after testing.

Environment

Cloud Provider	Amazon Web Services (AWS)
Primary Services	Amazon EC2, Instance Metadata Service, AWS Systems Manager Session Manager, IAM, STS, CloudFormation

Account Context	TestAccount1 / AdministratorAccess
Stack Name	IMDS
Template Source	Provided CloudFormation template URL from the lab
Instances	IMDSv1 and IMDSv2
IAM Role / Instance Profile	SSMClient
Metadata Endpoint	http://169.254.169.254/latest/meta-data/iam/security-credentials/
IMDSv1 Result	Simple curl returned role name and temporary credential JSON
IMDSv2 Simple Curl Result	401 Unauthorized
IMDSv2 Required Flow	PUT token, store TOKEN, retrieve ROLE_NAME with token header, retrieve credentials with token and role name
Cleanup	Deleted stack and instances after validation

Architecture



IMDSv2 requires a session token in request headers; IMDSv1 can expose role credentials with simple GET requests.

Figure 1 - IMDSv1 simple metadata access compared with IMDSv2 token-based metadata access.

Implementation Summary

1. Signed into TestAccount1 using AdministratorAccess.
2. Created a new CloudFormation stack named IMDS from the provided lab template.
3. Created and validated the IMDSv2 instance and IMDSv1 instance.
4. Enabled IMDSv1 behavior on the IMDSv1 instance by setting metadata version to V1 and V2, token optional.
5. Connected to IMDSv1 using Session Manager.
6. Ran curl against the instance metadata security-credentials path and retrieved the SSMClient role name.
7. Ran curl against the SSMClient path and retrieved temporary role credential fields, including AccessKeyId, SecretAccessKey, Token, and Expiration. Sensitive values were redacted.
8. Terminated the IMDSv1 Session Manager connection.
9. Connected to the IMDSv2 instance.
10. Tried the same simple curl request and received a 401 Unauthorized response.
11. Requested an IMDSv2 token using a PUT request and a defined TTL.
12. Used the token header to retrieve the role name and stored it as ROLE_NAME.
13. Used the token header and role name to retrieve the temporary credential JSON.
14. Deleted the IMDS stack and instances after the lab.

Command Patterns

IMDSv1 simple credential retrieval pattern:

```
curl http://169.254.169.254/latest/meta-data/iam/security-credentials/  
curl http://169.254.169.254/latest/meta-data/iam/security-credentials/SSMClient
```

IMDSv2 token-required credential retrieval pattern:

```
TOKEN=$(curl -X PUT "http://169.254.169.254/latest/api/token" \  
-H "X-aws-ec2-metadata-token-ttl-seconds: 21600")  
  
ROLE_NAME=$(curl -H "X-aws-ec2-metadata-token: $TOKEN" \  
"http://169.254.169.254/latest/meta-data/iam/security-credentials/")  
  
curl -H "X-aws-ec2-metadata-token: $TOKEN" \  
"http://169.254.169.254/latest/meta-data/iam/security-credentials/$ROLE_NAME"
```

Evidence

Figure 2 - IMDSv1 Returns Temporary Credentials with Simple Curl Requests

```
sh-5.2$ curl http://169.254.169.254/latest/meta-data/iam/security-credentials/SSMClient
sh-5.2$ curl http://169.254.169.254/latest/meta-data/iam/security-credentials/SSMClient

{"Code": "Success",
 "LastUpdated": "2026-07-28T17:00:51Z",
 "Type": "AWS-HMAC",
 "AccessKeyId": "ASIA",
 "SecretAccessKey": "REDACTED",
 "Token": "REDACTED",
 "Expiration": "2026-07-28T23:44:24Z"}
sh-5.2$
```

The IMDSv1 evidence shows a simple curl request retrieving the SSMClient role name, followed by another curl request retrieving a credential response with Code Success, Type AWS-HMAC, AccessKeyId beginning with ASIA, SecretAccessKey, Token, and Expiration. Sensitive values were redacted.

Figure 3 - IMDSv2 Rejects the IMDSv1-Style Request

```
sh-5.2$ curl http://169.254.169.254/latest/meta-data/iam/security-credentials/
<?xml version="1.0" encoding="iso-8859-1"?>
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
    "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" lang="en">
  <head>
    <title>401 - Unauthorized</title>
  </head>
  <body>
    <h1>401 - Unauthorized</h1>
  </body>
</html>
sh-5.2$
```

The IMDSv2 unauthorized evidence shows the same simple curl request against the metadata security-credentials path returning a 401 Unauthorized response. This confirms tokenless metadata retrieval is blocked.

Figure 4 - IMDSv2 Retrieves Credentials Only After Token-Based Requests

```
sh-5.2$ TOKEN=$(curl -X PUT "http://169.254.169.254/latest/api/token" -H "X-aws-ec2-metadata-token-ttl-seconds: 21600")
% Total % Received % Xferd Average Speed Time Time Time Current
% Total % Received % Xferd Average Speed Time Time Time Current
100 56 100 56 0 0 12999 0 --:--:-- --:--:-- --:--:-- 14000
sh-5.2$ ROLE_NAME=$(curl -H "X-aws-ec2-metadata-token: $TOKEN" "http://169.254.169.254/latest/meta-data/iam/security-credentials/")
% Total % Received % Xferd Average Speed Time Time Time Current
% Total % Received % Xferd Average Speed Time Time Time Current
100 9 100 9 0 0 2120 0 --:--:-- --:--:-- --:--:-- 2250
sh-5.2$ curl -H "X-aws-ec2-metadata-token: $TOKEN" "http://169.254.169.254/latest/meta-data/iam/security-credentials/$ROLE_NAME"
{"Code": "Success",
 "LastUpdated": "2026-07-28T17:00:56Z",
 "Type": "AWS-HMAC",
 "AccessKeyId": "ASIA",
 "SecretAccessKey": "REDACTED",
 "Token": "REDACTED",
 "Expiration": "2026-07-28T23:44:24Z"}
sh-5.2$
```

The IMDSv2 exposure evidence shows the token workflow: requesting a token with PUT, using the token header to retrieve the role name, then using the token header and role name to retrieve temporary credential fields. Sensitive values were redacted.

Security Analysis

IMDS provides instance metadata and, when an instance profile is attached, temporary role credentials. Those credentials are not static AKIA access keys; they are STS-style temporary credentials that include an access key,

secret access key, and session token.

IMDSv1 is risky because metadata can be queried with simple unauthenticated HTTP GET requests from the instance. If an application can be tricked into requesting metadata through SSRF, role credentials can be exposed.

IMDSv2 adds a required session token. The client first sends a PUT request to obtain a token, then passes that token in the X-aws-ec2-metadata-token header for metadata requests.

The token requirement breaks many simple SSRF paths because the attacker needs more than a single metadata URL fetch. The request must include a specific method and header workflow.

IMDSv2 is not a complete compromise-prevention control. If an attacker already has shell access or code execution on the instance, they may still be able to request a token and retrieve credentials.

The damage from exposed metadata credentials depends on the IAM role permissions. Least privilege on the instance profile remains critical.

Lessons Learned

EC2 IAM roles use instance profiles to provide temporary credentials to instances.

The metadata service is reachable from the instance at 169.254.169.254.

IMDSv1 can expose role credentials with simple curl requests.

IMDSv2 requires a token and token header on metadata requests.

IMDSv2 reduces SSRF risk but does not remove the need for least privilege, application security, and monitoring.

Sensitive credential values should always be redacted from screenshots and portfolio evidence.

Production Improvements

- * Require IMDSv2 on all EC2 instances using HttpTokens=required.
- * Set the metadata hop limit to the minimum needed for the workload.
- * Disable metadata access entirely on instances that do not need it.
- * Use least-privilege IAM roles for EC2 instance profiles.
- * Use launch templates or infrastructure-as-code guardrails so instances cannot be launched with IMDSv1.
- * Monitor for metadata option changes with CloudTrail, EventBridge, AWS Config, and Security Hub controls.
- * Harden web applications against SSRF with input validation, allowlists, and egress controls.
- * Avoid storing credentials in AMIs, user data, local files, or application configuration.

Skills Demonstrated

Amazon EC2	Instance Metadata Service	Instance profiles

IMDSv1 vs IMDSv2	STS temporary credentials	SSRF risk
Session Manager	curl testing	Lab cleanup

Resume Bullet

RESUME

Compared IMDSv1 and IMDSv2 behavior on EC2 instances by retrieving instance profile credentials through IMDSv1, validating IMDSv2 tokenless access failure, completing the IMDSv2 token-based request flow, and documenting metadata-service credential exposure risks and production hardening controls.

STAR Interview Story

Situation: The prior lab showed static access keys in local configuration files; this lab examined how EC2 instance profile credentials are exposed through the metadata service.

Task: Compare IMDSv1 and IMDSv2 credential retrieval behavior and document the security difference.

Action: I created the IMDS stack, configured separate IMDSv1 and IMDSv2 instances, used curl to retrieve role credentials from IMDSv1, confirmed tokenless access failed on IMDSv2, then used the IMDSv2 token, role-name, and header workflow to retrieve credentials before deleting the stack.

Result: The lab demonstrated why IMDSv2 is required to reduce SSRF-based credential theft while reinforcing that least-privilege IAM roles and application hardening are still necessary.

Version History

v1.0.0	July 28, 2026	Initial documented implementation. Created IMDS stack, compared IMDSv1 and IMDSv2 metadata access behavior, demonstrated IMDSv1 credential retrieval, validated IMDSv2 unauthorized response for tokenless access, completed IMDSv2 token-header credential retrieval, deleted stack and instances, and embedded provided evidence using portfolio documentation standard v1.0.1.

References

- * Cloud Security Lab a Week (S.L.A.W.) - Experience the Danger of the Mysterious Metadata Service v1.
- * User-provided IMDSv1 credential exposure evidence screenshot.
- * User-provided IMDSv2 unauthorized evidence screenshot.
- * User-provided IMDSv2 token-based credential retrieval evidence screenshot.
- * Project 37 - Explore Access Key Exposure and Static Credential Risk.